SECCIÓN 4.9

Clasificación de malware por comportamiento

Temas de esta sección:

- Por qué clasificar por comportamiento y no por nombre de detección
- La clasificación como hipótesis, no como afirmación
- Pregunta central: ¿qué está intentando hacer esta actividad?
- Downloader, dropper, infostealer, ransomware, RAT/backdoor
- Worm/propagación, cryptominer, wiper, spyware, fileless
- Comportamientos combinados y niveles de certeza
- Cómo documentar sin afirmar de más

En SOC muchas veces no tenemos la respuesta exacta sobre la familia del malware. Por eso, la clasificación por comportamiento debe ser una hipótesis basada en evidencia, no una afirmación absoluta.

Es ransomware.	La actividad es compatible con ransomware, debido a modificación masiva de archivos, cambio de extensión, eliminación de shadow copies y creación de nota de rescate.
Es C2.	Se observan conexiones HTTPS periódicas cada 60 segundos desde un binario no firmado ubicado en C:\Users\Public\. El patrón es compatible con posible comunicación C2.
Es un infostealer.	El proceso system_update.exe accedió a Chrome Login Data y Cookies, creó collected.zip y realizó un upload HTTPS. La actividad es compatible con comportamiento de infostealer.

Una misma amenaza puede tener múltiples comportamientos. El analista ordena la secuencia:

1	Documento ejecuta PowerShell	EJECUCIÓN INICIAL
2	PowerShell descarga update.exe	DOWNLOADER
3	update.exe crea tarea programada	PERSISTENCIA
4	update.exe accede a cookies	INFOSTEALER
5	update.exe sube collected.zip	EXFILTRACIÓN
6	update.exe mantiene conexión periódica	POSIBLE C2

Niveles de certeza para comunicar:

BAJA | MEDIA | ALTA | CONFIRMADA

Tipos con comportamientos específicos que requieren clasificación distinta:

WORM	SMB hacia muchos hosts · mismo archivo en múltiples endpoints · propagación sin intervención del usuario · conexión a múltiples IPs internas	Compatible con propagación tipo worm. Revisar alcance y segmentación.
CRYPTOMINER	CPU alto sostenido · proceso desconocido con alto consumo · conexión a pool de minería · xmrig.exe o variante · proceso oculto o renombrado	Compatible con cryptominer. Riesgo: disponibilidad e impacto de recursos.
WIPER	Eliminación masiva de archivos · sobrescritura de MBR · servicios detenidos · volumen shadows eliminados · sistemas caídos sin ransomware	Compatible con wiper. Escalamiento inmediato — posible impacto destructivo.
SPYWARE	Screen capture periódico · keylogger activo · acceso a micrófono/cámara · envío periódico de pequeños volúmenes · proceso en background	Compatible con spyware. Revisar qué datos fueron accedidos y enviados.
FILELESS	PS encoded cmd en memoria · WMI subscription para persistencia · LOLBin abuse sin archivo en disco · solo evidencia en EDR memory / registry	Compatible con fileless malware. Sin archivo — evidencia en logs y memoria.

4.9 | Cómo documentar clasificación sin afirmar de más

El lenguaje que usamos en el ticket o escalamiento define si somos precisos o generamos falsas alarmas:

✘ Frases que evitar (afirman sin evidencia completa):

- 'Es ransomware.'
- 'El equipo fue comprometido.'
- 'Hay exfiltración.'
- 'Es C2 confirmado.'

✔ Frases correctas (describen con el nivel de evidencia disponible):

- 'La actividad es compatible con ransomware, basado en cifrado masivo, extensión cambiada y eliminación de shadow copies.'
- 'Se observó comportamiento compatible con infostealer: acceso a Chrome Login Data, creación de zip y upload externo.'
- 'La secuencia es compatible con posible C2: beaconing periódico desde binario no firmado en ruta pública, creado hoy.'
- 'Sin evidencia confirmada de exfiltración. Se observó compresión de archivos sensibles y descarga previa. Requiere validación.'

La pregunta que guía todo: ¿qué evidencia tengo y qué puedo afirmar con esa evidencia? No más, no menos.